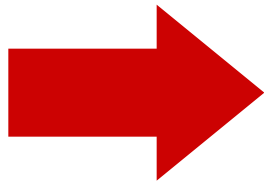


Seguridad distribuida en la red y centralizada en los sistemas

El Reto en la Seguridad

- Los sistemas de Tecnologías de la Información...
 - ... cambian rápidamente
 - ... son cada vez más complejos

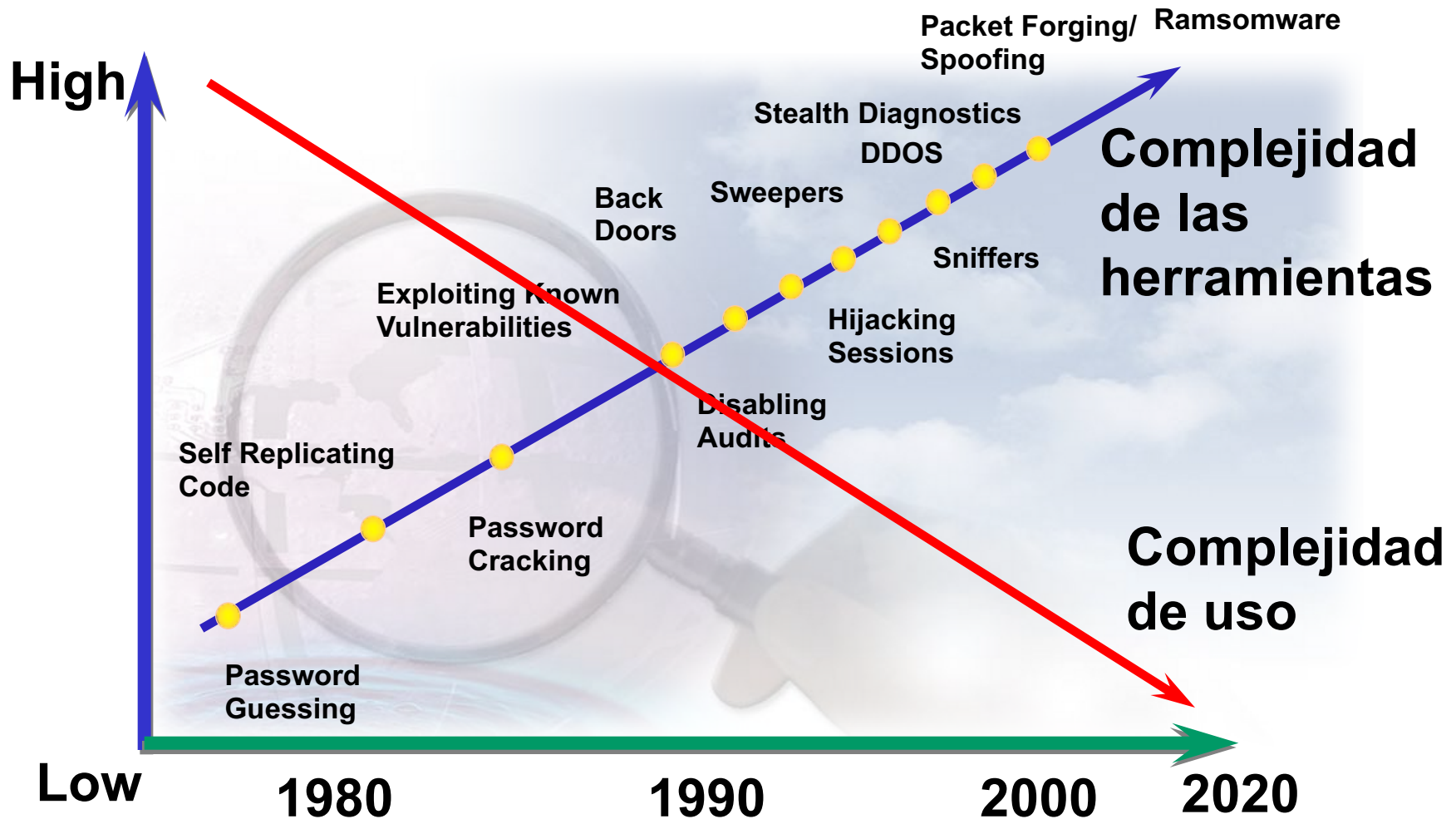
Y los “Hackers” son más sofisticados, y hacer “Hacking” cada vez más fácil



**¡El nivel de seguridad
debe crecer también!**

¡Teniendo en cuenta el coste!

Hackers: más peligroso y más fácil



Seguridad

ISO- 7498 “establece el modelo de referencia para la interconexión de sistemas abiertos” → “Modelo de referencia OSI”

Seguridad informática

- Mecanismos que minimizan la vulnerabilidad de bienes y recursos
 - un bien es algo de valor
 - la vulnerabilidad es la debilidad que se puede explotar para violar un sistema o la información que contiene
- Desarrollo de protocolos y mecanismos para preservar la seguridad.

Temas legales

En varios países el uso de información cifrada está prohibido

Los temas de seguridad son muy peliagudos y los Gobiernos tratan de implantar reglas (o estándares de cifrado) que ellos mismos puedan descifrar fácilmente

“seguridad vs privacidad”

Conceptos

- “**seguridad de una red**” implica la seguridad de cada uno de los dispositivos de la red
- “**hacker**”: tiene el objetivo demostrar que algo no es seguro
- “**cracker**”: utiliza sus ataques para sacar beneficio económico o perjudicar
- “**lamer**”: utiliza herramientas existentes. No crea nada nuevo
- “**Amenaza o ataque**”: intento de sabotear una operación o la propia preparación para sabotearla (poner en compromiso)

Tipos de amenazas

- **Compromiso:** la entidad atacante obtiene el control de algún elemento interno de la red, *por ejemplo utilizando cuentas con password triviales o errores del sistema*
- **Modificación:** la entidad atacante modifica el contenido de algún mensaje o texto
- **Suplantación:** la entidad atacante se hace pasar por otra persona
- **Reenvío:** la entidad atacante obtiene un mensaje o texto en tránsito y más tarde lo reenvía para duplicar su efecto
- **Denegación de servicio:** la entidad atacante impide que un elemento cumpla su función

Servicios ofrecidos por la “seguridad”

Confidencialidad: ¿lo ha interceptado alguien más?

Integridad: ¿puedo asegurar que este mensaje esta intacto?

Autenticación: ¿es realmente quien dice ser?

No repudio: ¿ha enviado/recibido esto realmente?

Control de Acceso: ¿tiene derechos a hacer lo que pide?

Auditoria: ¿qué ha pasado aquí?

Alarma: ¿está pasando algo ahora?

Disponibilidad: El servicio debe estar accesible en todo momento

Tema de seguridad

- 1.- Secretos: criptografía
- 2.- Protocolos de seguridad
- 3.- Aplicaciones y seguridad
- 4.- Redes y seguridad

Clasificación de problemas de seguridad

Los problemas de seguridad de las redes pueden dividirse de forma general en cuatro áreas interrelacionadas:

*1.-El **secreto**, encargado de mantener la información fuera de las manos de usuarios no autorizados.*

*2.-La **validación de identificación**, encargada de determinar la identidad de la persona/computadora con la que se esta hablando.*

*3.-El control de **integridad**, encargado de asegurar que el mensaje recibido fue el enviado por la otra parte y no un mensaje manipulado por un tercero.*

*4.-El **no repudio**, encargado de asegurar la “firma” de los mensajes, de igual forma que se firma en papel una petición de compra/venta entre empresas.*

Seguridad (1/4): Secretos

Criptografía

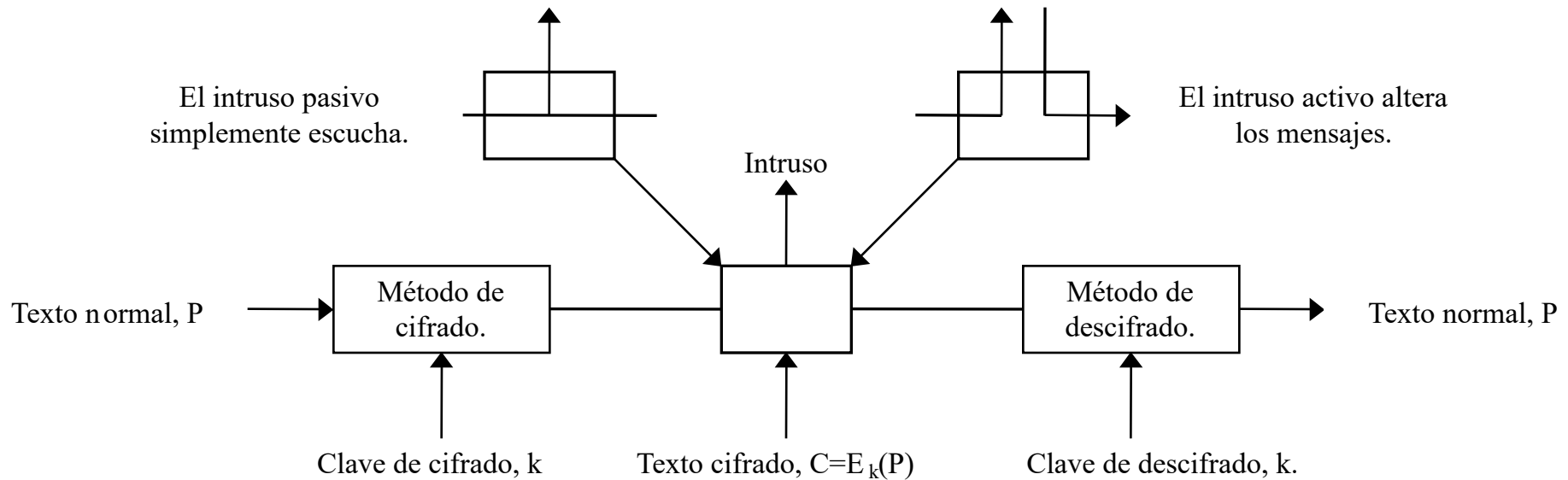
Criptografía y criptoanálisis

KRYPTOS = oculto GRAPHE = escrito

- El **criptoanálisis** se encarga de descifrar los mensajes.
 - Los intrusos utilizan estas técnicas.
- La **criptografía** busca métodos más seguros de cifrado.
 - Criptografía clásica. Algoritmo secreto. Cifrados por sustitución y transposición
 - Criptografía moderna. Algoritmo público. Cifrados en base a claves que se mantienen secretas.

Cifrado: codificación de los mensajes

Con clave simétrica (misma clave k)



El texto normal (P) se transforma (cifra) mediante una función que tiene como parámetro una clave k

$C = E_k(P)$ es el texto cifrado (C) obtenido a partir de P, usando la clave k y la función matemática E_k para codificar

$P = D_k(C)$ es el descifrado de C para obtener el texto normal P

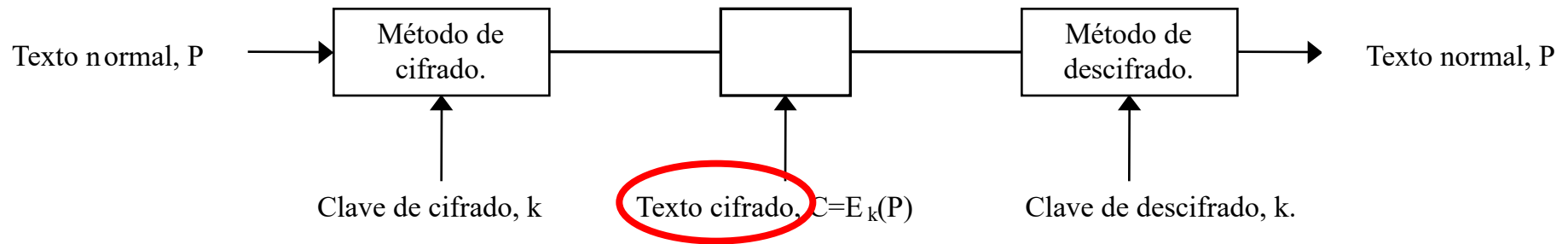
Cifrado y descifrado

$$D_k(E_k(P)) = P$$

E y D son sólo funciones matemáticas parametrizadas con la clave k
Estas funciones $E()$ y $D()$ **son conocidas** por el criptoanalista,
pero no la clave.

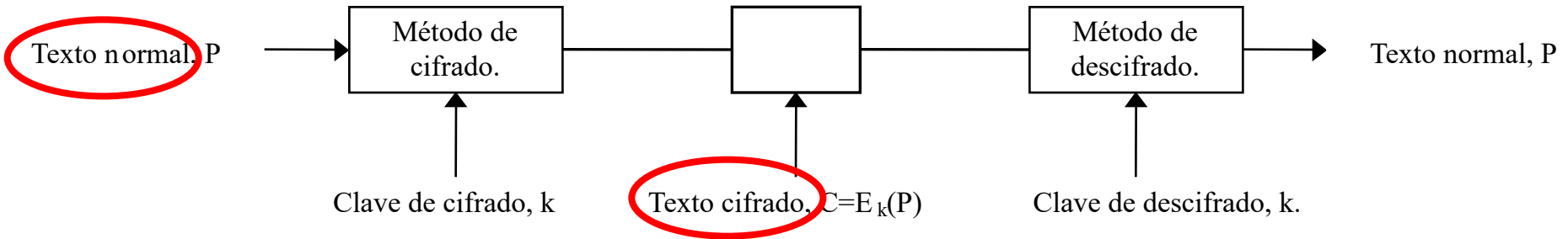
- 1.- La cantidad de esfuerzo necesario para inventar, probar e instalar un método nuevo (funciones E y D) cada vez que el viejo es conocido hace impracticable mantenerlo en secreto.
- 2.- Este método de cifrado con claves, permite “cambiar fácilmente de método” de cifrado simplemente con cambiar la clave

Puntos de partida del criptoanalista



1.- conoce sólo texto cifrado

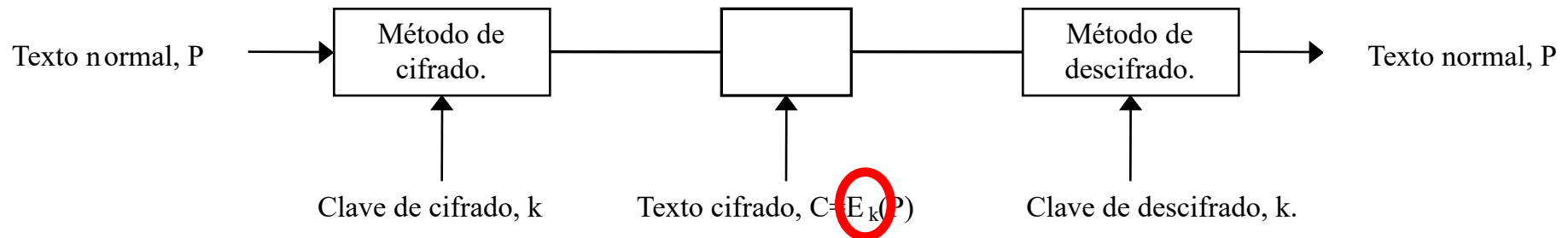
Puntos de partida del criptoanalista



2.- conoce un texto cifrado y el texto normal al que pertenece

Texto normal conocido

Puntos de partida del criptoanalista



3.- dispone del sistema de cifrado. Puede escoger un texto normal y cifrarlo

texto normal seleccionado

Principios criptográficos fundamentales

- 1.- Introducir **redundancia** (relleno) en los mensaje que permita acotar la posibilidad de ataque y/o en su caso, detectar fácilmente el sabotaje
 - CRCs
 - funciones hash de los mensajes
- 2.- Introducir una **marca temporal** en los mensajes, permite restringir los mensajes cifrados a un intervalo de tiempo, filtrando duplicaciones de mensajes viejos

Ejemplos de cifrado

1. Relleno de una sola vez
2. Criptografía cuántica
3. Criptografía clásica
 - sustitución
 - transposición
4. Criptografía moderna
 - algoritmos de clave privada
 - algoritmos de clave pública

Rellenos de una sola vez

Se escoge una cadena como clave secreta, por ejemplo “En un lugar d...”, y se va aplicando la función XOR sobre el texto normal a cifrar, bit a bit.

Texto normal o mensaje P = "texto cifrado"

Cadena de cifrado "En un lugar de la Mancha de cuyo nombre..."

Texto original	t	e	x	t	o		c	i	f	r	a	d	o
Codificación ASCII (hex)	74	65	78	74	6F	20	63	69	66	72	61	64	6F
Texto de cifrado	E	n		u	n		l	u	g	a	r		d
Codificación ASCII (hex)	45	6E	20	75	6E	20	6C	75	67	61	72	20	64
<i>Codificación cifrada (hex)</i>	<i>31</i>	<i>0B</i>	<i>58</i>	<i>01</i>	<i>01</i>	<i>00</i>	<i>0F</i>	<i>1C</i>	<i>01</i>	<i>13</i>	<i>13</i>	<i>44</i>	<i>0B</i>

$$0x74 \text{ XOR } 0x45 = 0111 \ 0100 \text{ XOR } 0100 \ 0101 = \mathbf{0011 \ 0001} = \mathbf{0x31}$$

Para el **descifrado**, simplemente volvemos a aplicar con XOR la misma cadena de cifrado.

Comentarios de rellenos de una sola vez (1/2)

Es un **método inviolable** porque cada texto normal posible es un candidato igualmente probable. *Esto es debido a la función XOR.*

Texto original	t	e	x	t	o		c	i	f	r	a	d	o
Codificación ASCII (hex)	74	65	78	74	6F	20	63	69	66	72	61	64	6F
Texto de cifrado	E	n		u	n		l	u	g	a	r		d
Codificación ASCII (hex)	45	6E	20	75	6E	20	6C	75	67	61	72	20	64
<i>Codificación cifrada (hex)</i>	<i>31</i>	<i>0B</i>	<i>58</i>	<i>01</i>	<i>01</i>	<i>00</i>	<i>0F</i>	<i>1C</i>	<i>01</i>	<i>13</i>	<i>13</i>	<i>44</i>	<i>0B</i>

Si capturo: 31 0B 58 01 01 00 0F 1C 01 13 13 44 0B
y aplico clave (incorrecta) ...

54 78 0C 60 72 73 7A 6F 71 76 7C 21 64

Texto original? 65 73 74 61 73 73 75 73 70 65 6F 65 6F

e s t a s s u s p e n s o

Comentarios de rellenos de una sola vez (2/2)

Inconvenientes

- el **manejo de la clave** entre el emisor y el receptor (llevarla, o comunicarla, define el mensaje máximo que se puede transmitir)
- la **sincronización** entre ambos para que no se cometa ningún error en la transmisión
 - Si faltase un bit a partir de ahí todos los datos estarían alterados.

Criptografía Cuántica (1/2)

- Se emiten fotones
- Luz se polariza
 - dependiendo del filtro usado se polariza de una forma u otra
- Si se intenta tocar la luz (captura información) se cambia la polarización
- Clave = filtros
- Empezando a comercializarse

Criptografía Cuántica (2/2)

Definición de 0



Definición de 1



Usuario A

1 0 0 1 1 1 0 0 1

Usuario B



Aplico estos filtros



Obtengo

N S N S N N N S S

Mira lo que
has
acertado

Utilizaremos esta cadena de bits como “relleno de una vez”

0 1 0 1

Si hay alguien escuchando siempre
acertará menos

Cifrado por sustitución

Este método consiste en desplazar (*a derecha o izquierda*) el alfabeto de texto cifrado k letras, siendo k la clave de cifrado. El descifrado es invertir el desplazamiento.

El cifrado por sustitución más antiguo conocido es el del emperador Julio Cesar.

Ejemplo: clave $k=+3$, texto normal P ="ataque"

Texto normal: **abcdefghijklmnopqrstuvwxyz**

Clave: **defghijklmnopqrstuvwxyzabc**



Texto cifrado C: **dwdtxh**

Cifrado por sustitución

Mejora

Crear un alfabeto diferente para cada cifrado (biunívoco)

Si el alfabeto es de 26 letras:

26! posibilidades

Cifrado por sustitución: ataques

Ataque básico: estudiar las **propiedades estadísticas** de los lenguajes naturales y detectar las probabilidades (frecuencia relativa) de aparición de:

1 letra del alfabeto

inglés: e

castellano: vocales

digramas

castellano: de, en,

ingles: th, in

trigramas

castellano: del, que, ...

ingles: the, ing, and

Cifrado por sustitución: ataques

Otro enfoque posible es adivinar una palabra o frase probable en el **contexto**.

Tema financiero: dinero, euro, coste, ...

Tema informático: ordenador, comunicación, informática, ...

Ejemplo de descifrado por sustitución

Texto cifrado de una **compañía contable inglesa**:

CTBMNBYCTCBTJDSQXBNSGSTJCBTSWXC *TQTZCQVUJ*
QJSGSTJQZZMNQJSVLNSXVSZJUJDSTSJQ *UUSJUBXJ*
DSKSUJSNTKBGAQJZBGYQTLCTZBNYBNQJSW

Ataque: una palabra muy probable es “*financ*ial”

Tiene la letra **i** repetida, con cuatro letras intermedias entre su aparición:

financial

Buscamos letras repetidas en el texto cifrado con este espaciado.

Ejemplo de descifrado por sustitución

Texto cifrado de una **compañía contable inglesa**:

CTBMNB**YCTC**BTJDS**QXB**NSGSTJCBT**SWXC****TQTZ**CQVUJ
QJ**SGST**JQ**ZZMN**QJSV**LNSX**VSZJUJD**STS**J**QUUS**JUBXJ
DSKSUJSNTKBGAQJZBGYQTLCTZBNYBNQJSW

De las letras en negrita, la 1 y la 3 deben ser iguales:

financial

CTBMNB**YCTC**BTJDS**QXB**NSGSTJCBT**SWXC****TQTZ**CQVUJ
QJ**SGST**JQ**ZZMN**QJSV**LNSX**VSZJUJD**STS**J**QUUS**JUBXJ
DSKSUJSNTKBGAQJZBGYQTLCTZBNYBNQJSW

Ejemplo de descifrado por sustitución

CTBMNBY**CTC**BTJDS**QXB**NSGSTJCBT**SWXC****TQTZ**CQVUJ
QJ**SGST**JQ**ZZ**MNQJSVL**NSX**VSZJUJD**STS**J**QUUS**JUBXJ
DSKSUJSNTKBGAQJZBGYQTLCTZBNYBNQJSW

Solo 1 de ellas tiene también repetición con la a
“*financial*”= “_xCTQTZCQV”

Otros cifrados por sustitución (1/2)

Hay otros cifrados que están basados en tablas.

Cifrado de Polybius: se introduce el alfabeto y el texto normal se codifica en base a las coordenadas de las letras dentro de dicha tabla. La clave de este cifrado está en la disposición del alfabeto en la tabla.

(2,1)→	A	B	C	D	E	F	G	(n° FILA, n° COLUMNA)
	H	I	J	K	L	M	N	
	Ñ	O	P	Q	R	S	T	
	U	V	W	X	Y	Z	+	
HOLA=(2,1),(3,2),(2,5),(1,1)								

Otros cifrados por sustitución (2/2)

Cifrado de Trithemius: es un método de sustitución progresivo, donde el valor de k varía de forma conocida en los extremos.

Ejemplo: clave $k=+2$ y texto normal $P=“Hola”$

$\Rightarrow H(+2)=J, o(+3)=r, l(+4)=o, a(+5)=f::$

Por tanto el texto cifrado sería $C=“Jrof”$

Otros métodos: cifrado de Vigenere, ...

Cifrado por transposición

Los cifrados por sustitución conservan el orden de los símbolos de texto normal, mientras que los cifrados por transposición **reordenan las letras,**(*o los bits*)

Ejemplo: texto normal P = “La clave secreta es AR”, clave k = “cripto”

La clave k, se utiliza para reordenar columnas del texto normal (no debe tener letras duplicadas)

ordenación: “1-c 2-i 3-o 4-p 5-r 6-t”

Se coloca el texto normal

El texto cifrado se obtiene cogiendo el texto normal por columnas con la ordenación determinada por la clave

C = “Lvr tRacs csa aeeAlee “

cripto
152463
La cla
ve sec
retaes
AR

¿Transposición o sustitución?

Un texto está cifrado por **transposición**, cuando las frecuencias de las letras respecto al alfabeto se mantiene. Por ejemplo, la letra “a” seguirá apareciendo el 63% de las veces, mientras que el **sustitución**, si “a” se sustituye por “q”, entonces la letra “q” aparecerá el 63%.

Conocido el contexto del mensaje y buscando las diferentes posibilidades de combinación de letras en palabras comunes, el criptoanalista puede determinar “fácilmente” la longitud de la clave y posteriormente la ordenación de columnas.

Ejemplo de ataque a cifrado por transposición (1/2)

En el siguiente texto aparece la palabra "computer" y suponiendo que se han usado menos de 8 columnas (letras que tiene computer)

aauancvrlrerurnndltmeaeeepbytusticeatnpmeyiiicgo
gorchsrsoecnntiimihaooofpagsivtttpsitlbolrotoex

Si se han usado 2 columnas debe aparecer "cm"

Si se han usado 3 columnas debe aparecer "cp"

Si se han usado 4 columnas debe aparecer "cu"

Si se han usado 5 columnas debe aparecer "ct"

Si se han usado 6 columnas debe aparecer "ce"

aauancvrlrerurnndltmeaeeepbytusti**ce**atnpmeyiiicgo
gorchsrsoecnntiimihaooofpagsivtttpsitlbolrotoex

Ejemplo de ataque a cifrado por transposición (2/2)

Colocando el texto en 6
columnas

adigit
alcomp
uteris
amachi
nethat
cansol
veprob
lemsfo
rpeopl
ebycar
ryingo
utinst
ructio
nsgive
ntoit

No hace falta mirar entre columnas

adigitalcomputerisamachine
thatcansolveproblemsfor
peoplebycarryingout
instructions giventoit

Criptografía moderna

Mismas ideas básicas que la criptografía tradicional, la transposición y la sustitución (que pueden implementarse mediante circuitos), pero con distinta orientación.

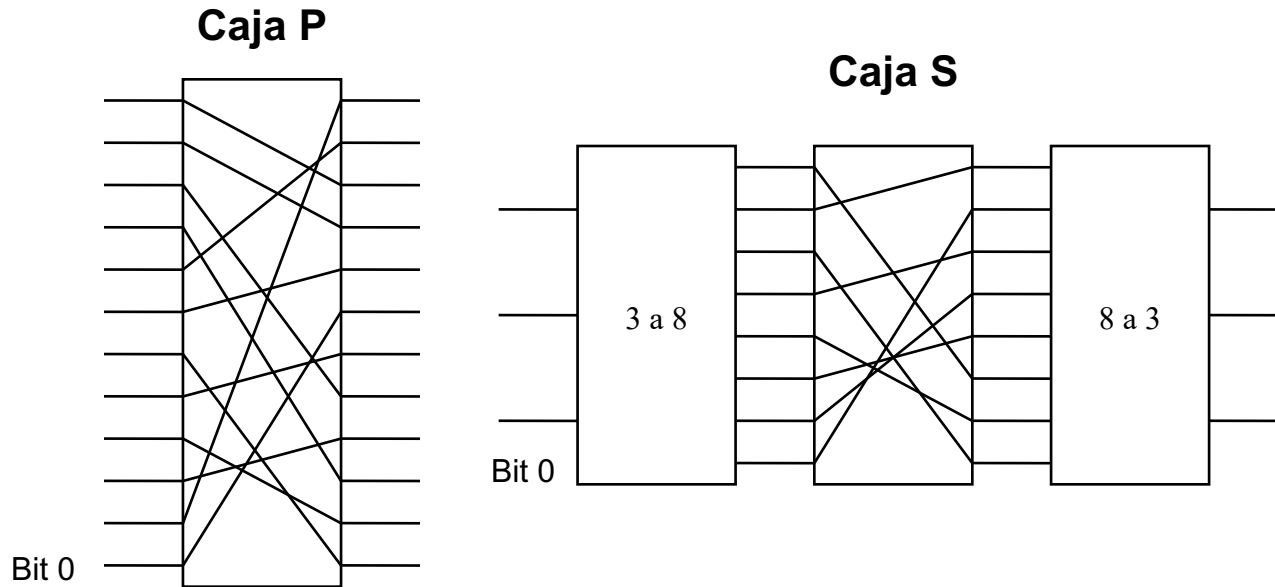
Criptografía tradicional

- algoritmos sencillos y secretos
- claves muy largas

Criptografía moderna

- algoritmos de cifrado complicados y conocidos
 - Si alguien obtiene cantidades enormes de texto cifrado, debe ser incapaz de descifrarlo

Ejemplo Circuitos P y S

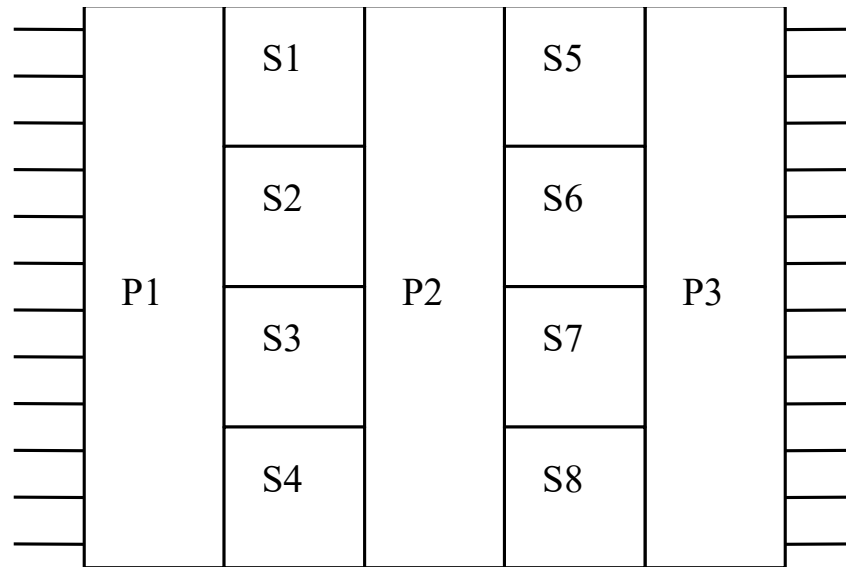


Circuito P de permutación o transposición: entrada/salida de 12 bits reordenados. Ejemplo 1010 1010 1010 (0xAAA) se convierte en 1110 0001 0011 (0xE13). Se mantienen los mismos bits pero no el orden.

Circuito S de sustitución: entrada/salida de 3 bits con decodificación/codificación (sustitución) interna. Ejemplo 000 se sustituye por 101. Ni el orden ni los bits se mantienen. Utilizan internamente una permutación.

Cifrado de producto: cascada de circuitos P y S

La potencia real de los circuitos P y S sólo se ve claramente cuando aparecen en cascada una serie completa de estas cajas para formar lo que se llama un cifrado de producto.



Cifrado de clave privada y pública (1/2)

- En el **cifrado de clave privada** las claves de cifrado y descifrado son la misma (o bien se deriva de forma directa una de la otra), debiendo mantenerse en secreto dicha clave. Ejemplos:
 - DES (Data Encryption Standard) y T-DES (o 3DES)
 - IDEA (International Data Encryption Algorithm)
 - AES (Advanced Encryption Standard) o Rijndael
- En el **cifrado de clave pública**, las claves de cifrado y descifrado son independientes, no derivándose una de la otra, por lo cual puede hacerse pública la clave de cifrado siempre que se mantenga en secreto la clave de descifrado. Ejemplo:
 - Cifrado RSA (Rivest, Shamir, Adleman)

Cifrado de clave privada y pública (2/2)

El cifrado de **clave privada**, es más rápido que el de clave pública (de 100 a 1000 veces), y por tanto se utiliza generalmente en el intercambio de información una vez establecida una sesión. Estas claves también son conocidas como claves de sesión o de cifrado simétricas, ya que en ambos extremos se posee la misma clave.

El cifrado de **clave pública** es más lento y por tanto se utiliza para intercambiar las claves de sesión. Como este algoritmo utiliza dos claves diferentes, una privada y otra pública el cifrado se conoce como cifrado asimétrico.

Notación para cifrado y descifrado en clave simétrica y asimétrica

- 1.- Con claves simétricas, cuando cifra el usuario A y utiliza su clave simétrica K_A :
 - $E_{K_A}(P)$ lo indicaremos como $K_A(P)$
 - $D_{K_A}(P)$ lo indicaremos también por $K_A^{-1}(P)$
- 2.- Con claves asimétricas, cuando cifra el usuario A y utiliza su clave K_A , formada por parte privada y parte pública:
 - Con parte pública $=E_{K_A}(P)$ lo indicaremos por $E_A(P)$
 - Con parte privada $=D_{K_A}(P)$ lo indicaremos por $D_A(P)$

Cifrado DES (Data Encryption Standard) (1/4)

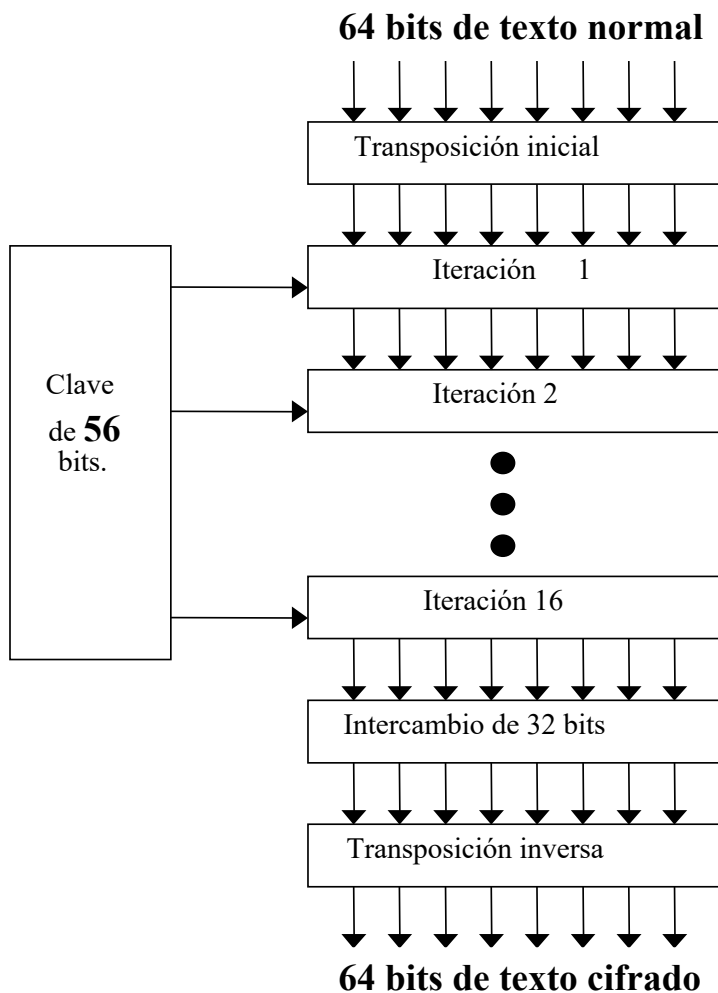
- Desarrollado por IBM a principios de los 70
- Se diseñó de forma que, fuera resistente a criptoanálisis y además sencillo para poder ser implementado en un circuito electrónico con la tecnología de los 70
- Al algoritmo también se le llama DEA (Data Encryption Algorithm)

DES puede ser descifrado probando todas las claves posibles con el hardware adecuado (“ataque de fuerza bruta”).

El texto normal se cifra

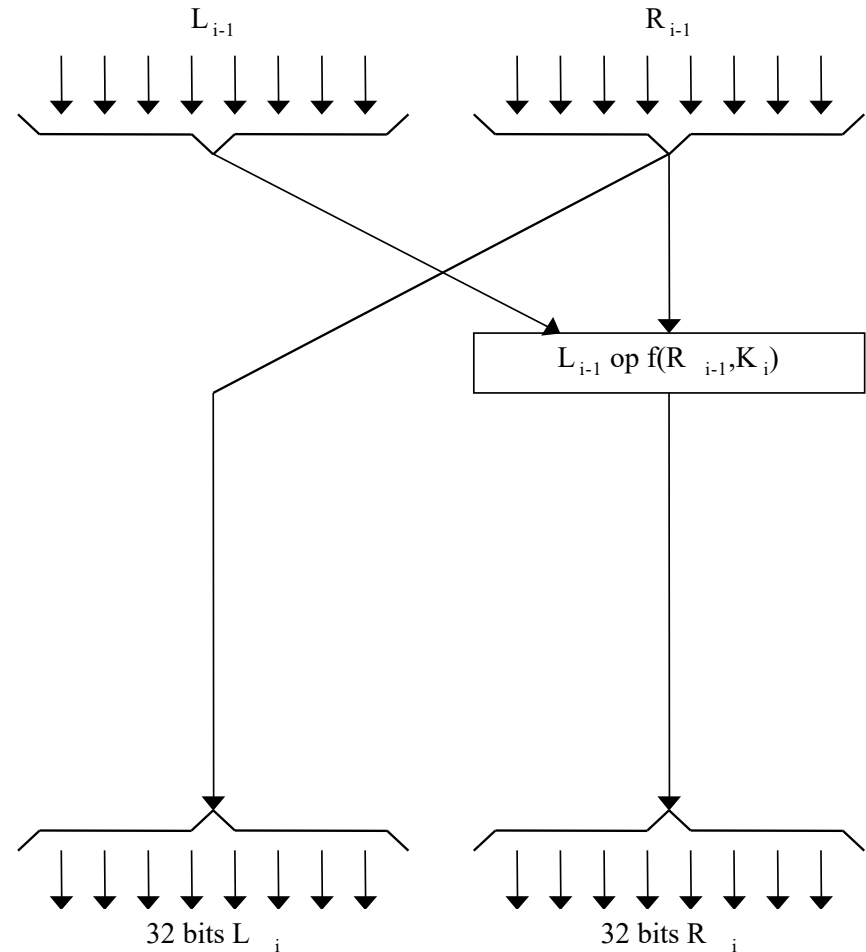
- en bloques de 64 bits (8 bytes). Produce 64 bits de texto cifrado
- El algoritmo tiene 19 etapas diferentes
- Claves de 56 bits

El descifrado se realiza con la misma clave que el cifrado, ejecutando los pasos en orden inverso.



19 etapas, donde la transposición final es la inversa de la inicial, y todas las etapas de iteración son funcionalmente iguales.

DES (2/4)



Bloque de iteración: tiene 2 entradas de 32 bits L_{i-1} y R_{i-1} , donde la salida de la derecha es el XOR a nivel de bit de la entrada izquierda L_{i-1} y una función $f()$ de la entrada derecha R_{i-1} y la clave de esta etapa K_i

DES (3/4)

La complejidad del algoritmo reside en la **función $f()$** del bloque de iteración, que consiste en:

- 1.- se construye un número de **48 bits**, E , expandiendo el R_{i-1} de 32 bits según una regla fija de transposición y duplicación
- 2.- se aplica un *XOR* a E y K_i .
- 3.- esta salida se divide en 8 grupos de 6 bits, alimentando a una caja S distinta. Cada una de las 2^6 entradas posibles a la caja S se transforma en una salida reducida a 4 bits a través de una tabla conocida
- 4.- por último las 8 salidas de las caja S de 4 bits se pasan a través de una caja P

Todas estas operaciones están recogidas en tablas, DES fácilmente implementable por HW

DES (4/4)

Y la clave?:

En cada una de las 16 iteraciones, se usa una clave diferente. Antes de iniciarse el algoritmo, se aplica *una transposición de 56 bits a la clave*.

Antes de cada iteración, la clave se divide en *dos unidades de 28 bits*, cada una de las cuales *se desplaza (gira)* hacia la izquierda una cantidad de bits *dependiente del número de iteración*.

K_i se deriva de esta clave girada aplicándole otra transposición de 56 bits. Además en cada etapa de iteración, se extrae y permuta de los 56 bits un subgrupo de 48 bits diferente para la XOR de la función $f()$.

¿Es seguro el DES?

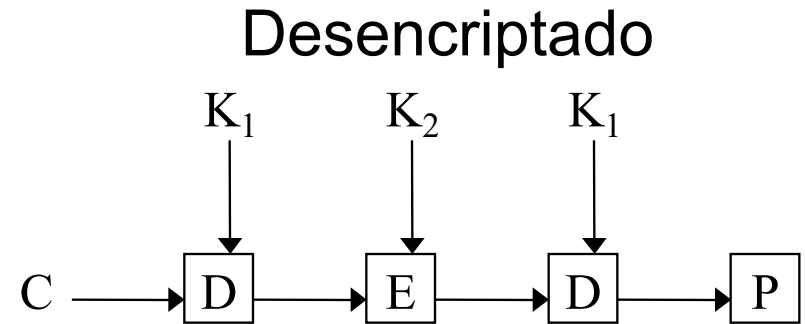
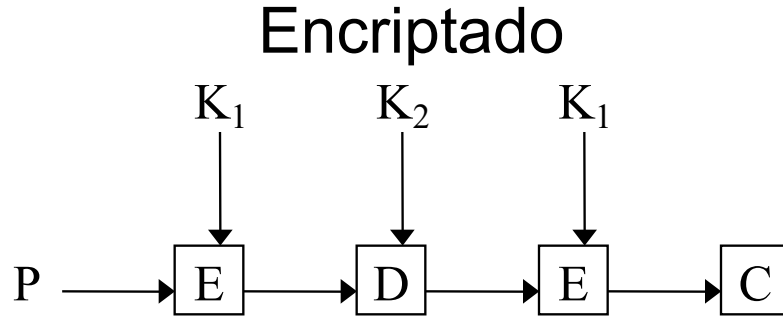
Dado un trozo pequeño de texto normal y el texto cifrado correspondiente, se puede encontrar **la clave** en unas horas con el hardware del DES, mediante una búsqueda exhaustiva del espacio de claves de 2^{56}

DES no es seguro

Doble DES: Ejecutar el **DES 2 veces**, con 2 claves de 56 bits distintas. Esto proporciona un espacio de claves de 2^{112}

Se ha desarrollado un método de ataque llamado “*encuentro a la mitad*” que lo hace también vulnerable con 2^{57} operaciones

Triple DES (ANSI X.9.52)



Se utilizan 2 claves (K_1 y K_2) y 3 etapas:

- 1.- el texto normal se cifra con K_1
- 2.- DES se ejecuta en modo de descifrado, usando K_2
- 3.- se hace otro cifrado usando K_1

Comentarios:

Porqué EDE (cifrado-descifrado-cifrado) y no EEE (cifrado-cifrado-cifrado)?

Si $K_1 = K_2$, T-DES = DES (uso del mismo HW)

En T-DES con EDE se usan sólo 2 claves ya que 112 bits de clave son suficientes para las aplicaciones comerciales.

La solución EEE es mucho más segura con clave de 168 bits.

Cifrado IDEA (International Data Encryption Algorithm)

Después de comprobar la debilidad del algoritmo DES en su forma simple, diversos trabajos propusieron nuevos métodos, de los cuales el más interesante e importante es el algoritmo IDEA.

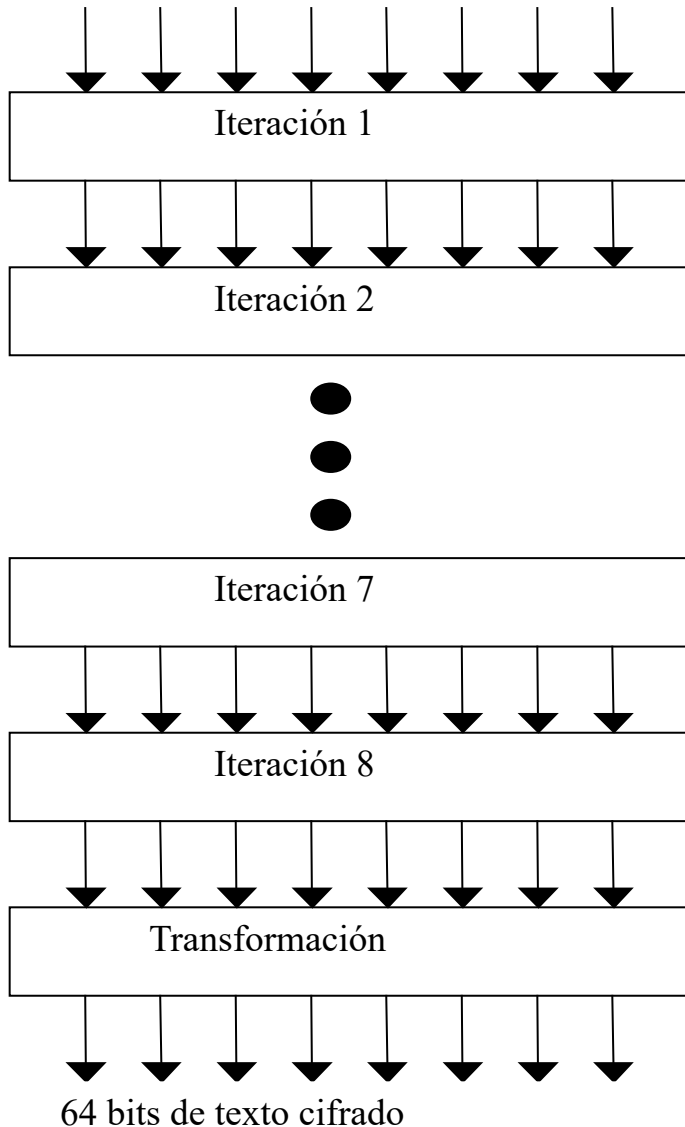
IDEA es un algoritmo de clave privada que **usa una clave de 128 bits**, lo que lo hará inmune durante décadas a los ataques de la fuerza bruta.

No hay ninguna técnica o máquina conocida actualmente que se crea que puede descifrar el algoritmo IDEA.

La estructura básica de IDEA se asemeja a DES en cuanto a que se alteran bloques de entrada de texto normal de 64 bits en una secuencia de iteraciones parametrizadas.

Esquema de IDEA (1/2)

64 bits de texto normal



Solo 8 iteraciones!

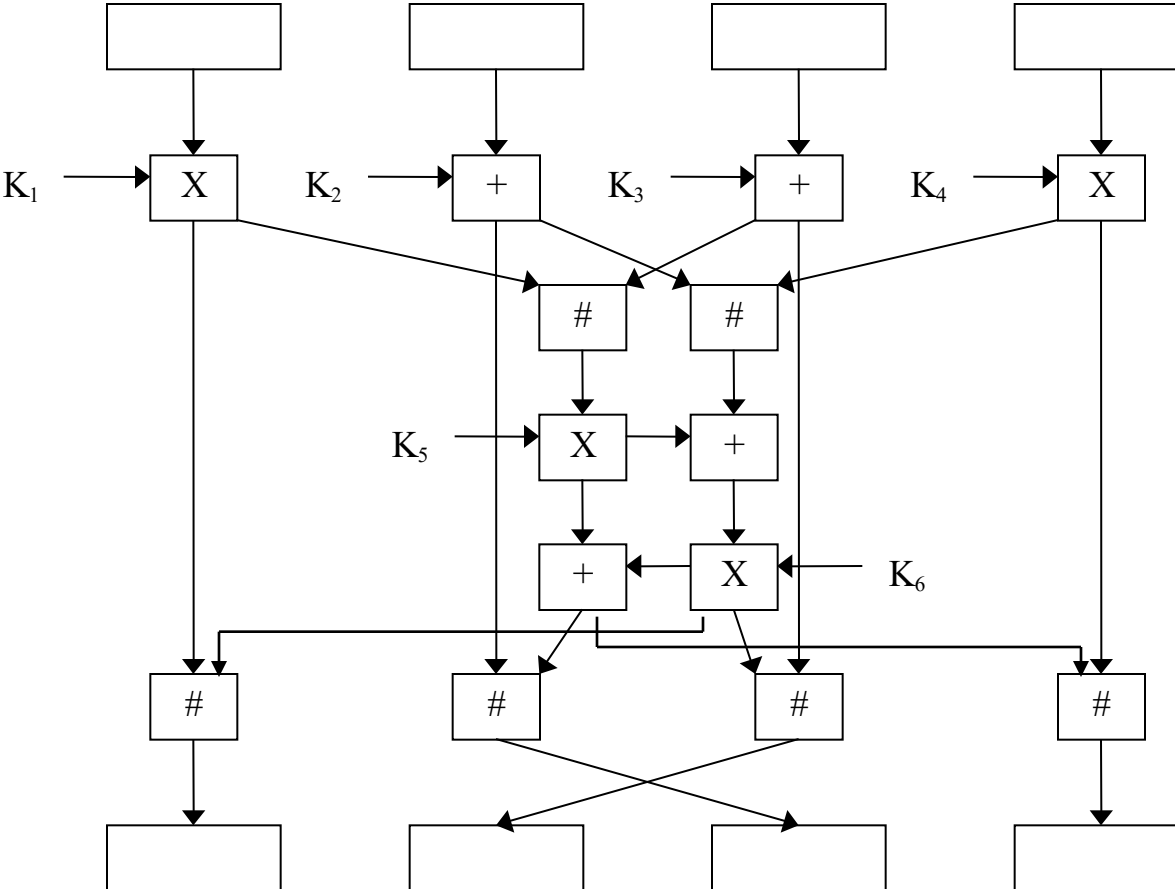
Debido a extensa alteración de bits
en cada iteración
y 1 transformación

Como con todos los cifrados de bloque, el algoritmo IDEA también puede usarse en el modo de realimentación de cifrado, (como el DES en el T-DES)

El descifrado usa el mismo algoritmo que el cifrado, sólo que con subclaves diferentes

Esquema de IDEA (2/2)

Cuatro bloques de entrada de 16 bits



Cuatro bloques de salida de 16 bits

+	Suma módulo 2^6 de 16 bits
X	Multiplicación módulo $2^{16}+1$ de 16 bits
#	OR EXCLUSIVO de 16 bits

La clave de 128 bits genera:

52 subclaves de 16 bits =>

6 subclaves * 8 iteraciones + 4
(para la transformación final)

} 3 operaciones

Advanced Encryption Standard (AES) o Rijndael

- Sucesor del DES y T-DES, adoptado como estándar en el NIST (National Institute for Standards and Technology) de EEUU en año 2000
- Es un algoritmo resultado de una competición pública, donde los vencedores fueron los belgas Joan Daemen y Vincent Rijmen, de ahí su nombre de Rijndael
- Consiste en cifrado por bloques de 128 bits y claves variables, con longitudes entre 128 y 256 bits

Otros

RC5	claves de hasta 2048 bits
Blowfish	claves de hasta 448 bits

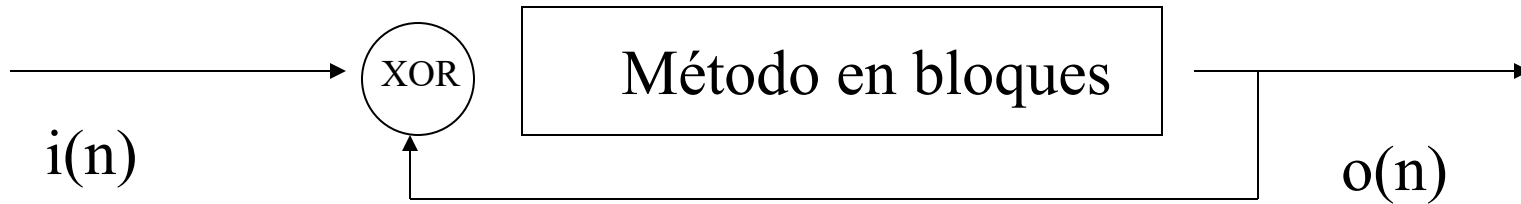
Los métodos basados en bloques, también se llaman **ECB (Electronic Code Book)** y son muy rápidos.

En general todos ellos procesan “bloques” de bits fijos. Un posible ataque sería mover bloques dentro de un mismo cifrado.

Posible solución:

- Cifrado basado en flujo, que operan por bloques, pero convolucionando (por ejemplo con una XOR) la salida actual con salidas anteriores o con la entrada. Ejemplos: RC2, RC4 y CAST. Estos métodos también se llaman **CBC (Cipher Block Chain)**

Métodos simétricos basados en flujo



Los métodos basados en flujo utilizan funciones XOR con métodos basados en bloques. Para descifrar utilizamos un sistema inverso (espejo).

Para cifrar:

$$o(1) = K[i(0)];$$

$$o(2) = K[i(1) \text{ XOR } o(1)];$$

...

$$o(n) = K[i(n-1) \text{ XOR } o(n-1)]$$

Para descifrar:

$$K^{-1}[o(1)] = i(0);$$

$$K^{-1}[o(2)] = i(1) \text{ XOR } o(1)$$

(como conocemos $o(1)$ hacemos XOR)

$$\text{Por tanto } i(1) \text{ XOR } o(1) \text{ XOR } o(1) = i(1)$$

...

$$K^{-1}[o(n)] = i(n-1) \text{ XOR } o(n-1);$$

(con XOR $o(n-1)$)

$$\text{Por tanto } i(n-1) \text{ XOR } o(n-1) \text{ XOR } o(n-1) = i(n-1)$$

Cifrados de clave pública

Históricamente, el problema de distribución de claves siempre ha sido la parte débil de la mayoría de criptosistemas. Si un intruso puede robar la clave, el sistema no vale nada.

En 1976, en la Universidad de **Stanford** (EEUU) se propuso un nuevo criptosistema, en el que:

- las claves de cifrado y descifrado son diferentes
- la clave de descifrado no puede derivarse de la clave de cifrado

En dicha propuesta, el algoritmo de cifrado $E()$ (parametrizado con una clave) y el algoritmo de descifrado $D()$ (con otra clave), tienen que cumplir las propiedades:

1. $D(E(P)) = P$
2. Es excesivamente difícil deducir $D()$ de $E()$ o viceversa
3. $E()$ no puede descifrarse

Algoritmo de cifrado de clave pública

El algoritmo de cifrado $E()$, descifrado $D()$ y la clave de cifrado, se hacen públicos (*de ahí el nombre de criptografía de clave pública*), pero se mantiene secreta la clave de descifrado.

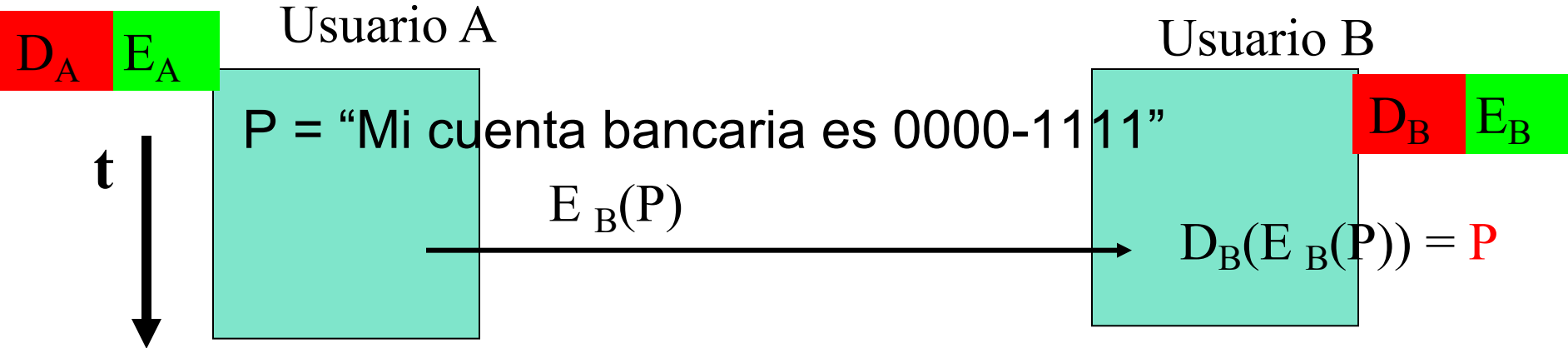
E_A es clave pública y D_A es clave secreta.

*Nueva notación: A
indica el propietario
de la clave*

Escenario de aplicación entre persona A y B:

A y B nunca han tenido contacto previo. Se supone que tanto la clave de cifrado de A, E_A , como la clave de cifrado de B, E_B , es información pública.

Uso de clave publica para enviar algo de forma segura



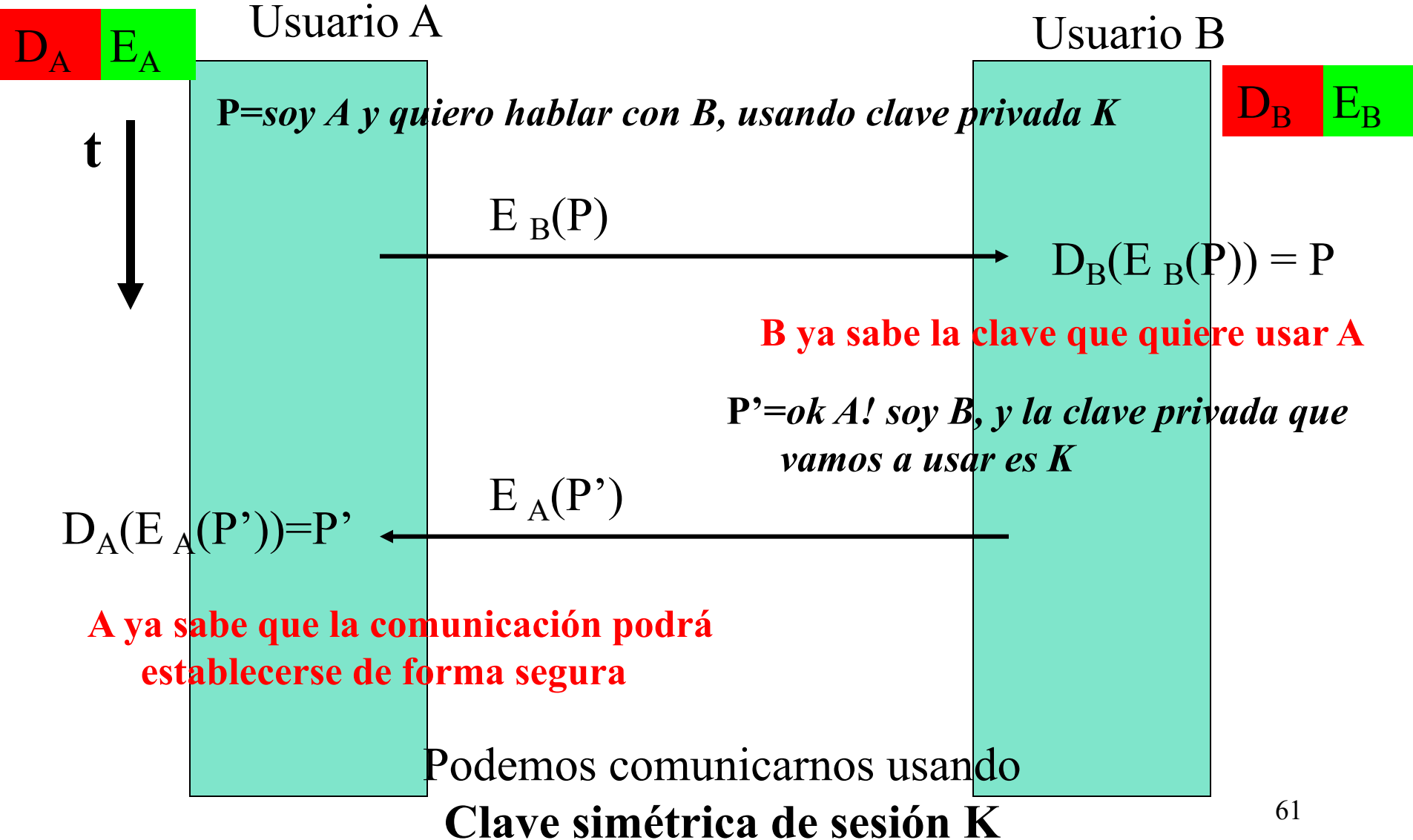
A toma su primer mensaje P , calcula $E_B(P)$ y lo envía a B

B entonces lo descifra aplicando su clave secreta D_B , es decir, calcula $D_B(E_B(P)) = P$

Nadie más que B, puede descifrar el mensaje $E_B(P)$, porque se supone que el sistema de cifrado es robusto y porque es demasiado difícil derivar D_B de la E_B públicamente conocida

B procede igual que A.

Uso de clave pública para intercambio de claves privadas



Cifrado RSA (Rivest, Shamir, Adleman, 1979)

El algoritmo RSA se basa en la dificultad de factorizar números grandes.

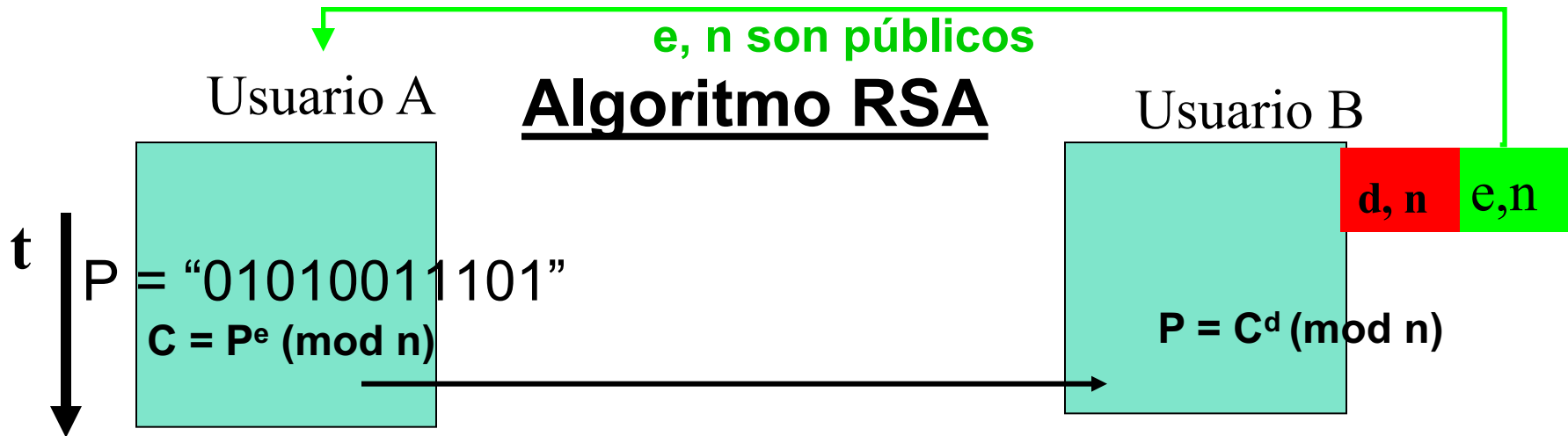
- Seleccionar dos números primos grandes, p y q (generalmente mayores que 10^{10} → 1024 bits).
- Calcular
$$n = p * q$$
$$z = (p-1) * (q-1)$$
 La función multiplicativa de Euler
- Seleccionar un número d primo relativo con z (sin ningún factor común)
- Encontrar e tal que $((e * d) \text{ modulo } z) = 1$

Los datos que serán públicos son el par (e,n) y privados (d,n) .

Si el criptoanalista pudiera factorizar n (conocido públicamente), podría encontrar p y q , y a partir de éstos, z .

Equipado con el conocimiento de z y de e , que es pública, puede encontrar d usando el algoritmo extendido de Euclides

$d = ((Y*z)+1)/e$ para $Y=1,2,3,...$ hasta encontrar un d entero



Dividimos el texto normal (considerado como una cadena de bits) en bloques P , que cumpla que $0 < P < n$

Una forma de realizarlo es tomar bloques P de k bits, donde k es el entero más grande para el que $2^k < n$, con $n = p * q$

Para cifrar el mensaje P , se calcula $C = P^e \pmod{n}$ y lo envía

Para descifrar C , calculamos $P = C^d \pmod{n}$

Además, se puede demostrar del RSA que $D(E()) = E(D())$

Es decir:

$$(p^e \pmod{n})^d \pmod{n} = p$$

Ejemplo de RSA (1/3): $A \rightarrow E_B() \rightarrow B$

Vamos a cifrar mediante RSA el nombre “suzanne”, con la codificación "a" $\rightarrow$ 1, "b" $\rightarrow$ 2, “c” $\rightarrow$ 3,...”s” $\rightarrow$ 19, etc.

1.- Seleccionar dos números primos grandes, p y q

$$\begin{aligned} p &= 3 \\ q &= 11 \end{aligned}$$

2.- Calcular

$$\begin{aligned} n &= n = 33 \\ z &= z = 20 \quad (p-1)(q-1) \end{aligned}$$

3.- Seleccionar un número d primo relativo con z (sin ningún factor común) $d = 7$

4.- Encontrar e tal que $((e * d) \text{ modulo } z) = 1$

$$\begin{aligned} e * 7 \text{ mod } 20 &= 1 \\ \Rightarrow e &= 3 \end{aligned}$$

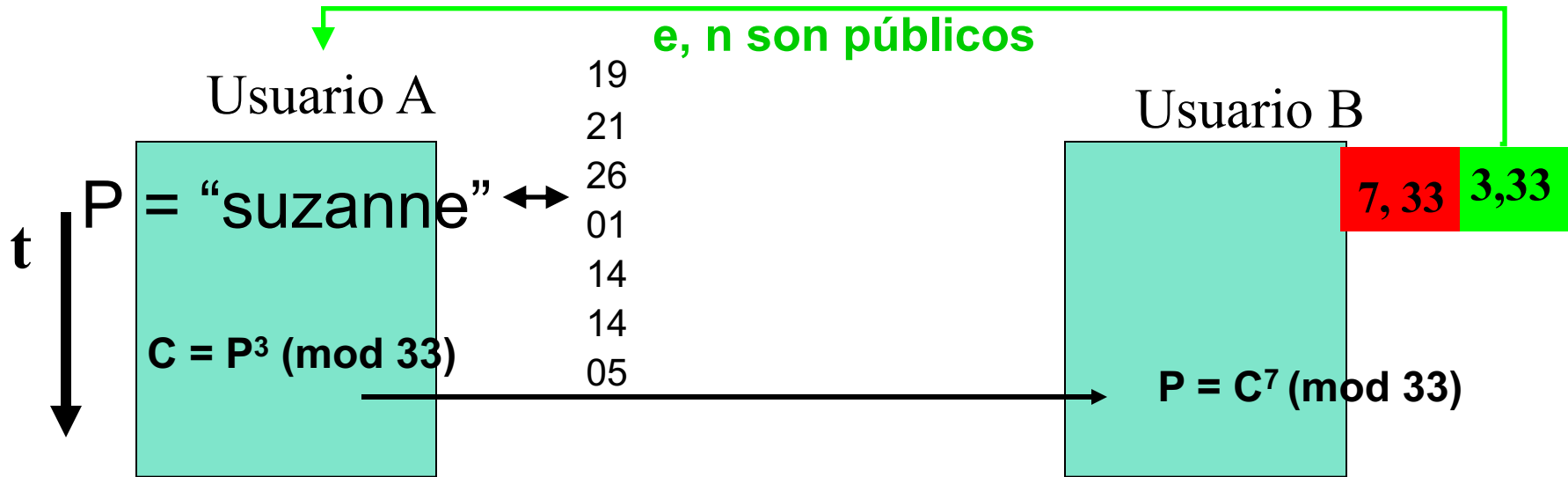
Clave pública es el par (e,n)

$$(e,n) = (3,33)$$

La clave privada es el par (d,n)

$$(d,n) = (7,33)$$

Ejemplo RSA (2/3)



Texto normal (P)			Texto cifrado (C)			Después del descifrado	
<u>Simbólico</u>	<u>Numérico</u>	<u>P^3</u>	<u>$C=P^3 \pmod{33}$</u>	<u>C^7</u>	<u>$C^7 \pmod{33}$</u>	<u>Simbólico</u>	
s	19	6859	28	13492928512	19	s	
u	21	9261	21	1801088541	21	u	
z	26	17576	20	1280000000	26	z	
a	01	1	01	1	01	a	
n	14	2744	05	78125	14	n	
n	14	2744	05	78125	14	n	
e	05	125	26	8031810176	05	e	

Ejemplo de RSA (3/3)

Dado que los números primos escogidos para el ejemplo son tan pequeños, P debe ser menor que 33, por lo que cada bloque de texto normal puede contener sólo un carácter (*sustitución monoalfabética* $2^k < n \rightarrow 2^k < 33 \rightarrow k = 5\text{bits}$).

Si hubiéramos **seleccionado p y q del orden de 10^{100}** podríamos tener n del orden de 10^{200} , por lo que cada **bloque** podría ser de hasta 664 bits (**83 caracteres** de 8 bits), contra 64 bits (8 caracteres de 8 bits) para el algoritmo DES.

Sin embargo, el **algoritmo RSA es demasiado lento** para poder cifrar grandes volúmenes de datos, por lo cual suele usarse para distribuir claves de sesión de una sola vez para su uso con los algoritmos DES, 3DES, IDEA, AES u otros semejantes.

PKCS Public Key Cryptography Standards

PKCS#1

RSA

PKCS#3

Clave secreta usando Diffie-Hellman

PKCS#11

API para dispositivos
criptográficos

PKCS#12

Formato para almacenar
claves

Comentarios sobre RSA

- 1.- Los matemáticos han estado tratando de **factorizar números grandes** durante los últimos 300 años y los resultados obtenidos es que se trata de un **problema excesivamente difícil de resolver.**

La factorización de un número de 200 dígitos requiere 4 mil millones de años de tiempo de cómputo y la factorización de un número de 500 dígitos requiere 10^{25} años, considerando una CPU con tiempo de instrucción de 1 microsegundo.

- 2.- Las claves son de tamaño variable, con un mínimo de 500 bits de longitud. *Por ejemplo, PGP, una aplicación para correo utiliza 512, 768 o 1024 bits*

Otros cifrados asimétrico y comentarios

Adicionalmente a RSA, existen otros métodos de resolución computacional imposible para poder resolver la función matemática inversa, mientras la directa es inmediata.

En general se trata de plantear/resolver un problema matemático:

- Factorización
- Curvas elípticas,
- Logaritmos discretos (ej. El Gamal),
- Raices cuadradas (ej. Rabin)

Comentarios sobre clave pública y privada: sesiones

En la práctica, por razones de velocidad y seguridad, todo el tráfico de datos se cifra usando criptografía de **clave secreta** (*DES, 3DES, IDEA, AES, ...*) que llamaremos clave de sesión o cifrado simétrico (*porque ambos extremos poseen la misma clave privada*) y la criptografía de **clave pública** se usa ampliamente para establecer la clave de sesión o también conocida como cifrado asimétrico (*porque ambas claves de cifrado y descifrado son diferentes*)

De esta forma, gestionamos una nueva clave secreta por conexión y mantenemos en seguridad las claves públicas.

Ejemplos de dispositivos HW para cifrar:

Cisco 1720 Series Router



- **VPN (Virtual Private Networks) Access**
 - Cisco IOS™ technologies
 - Security, QoS, management, reliability/scalability
 - RISC processor for encryption performance
 - **IPSec DES encryption performance: 512 Kbps for 256-byte packets**
 - Option for hardware-assisted encryption @ T1/E1
- **Flexibility**
 - Autosensing 10/100 Fast Ethernet + two WIC (WAN interface Card) slots + AUX port
 - Any combination of current 1600 WICs and 2600 dual serial WICs
- **Network Device integration**
 - Router-firewall-encryption-VPN tunnel server-DSU/CSU-NT1
 - Part of Cisco Networked Office stack

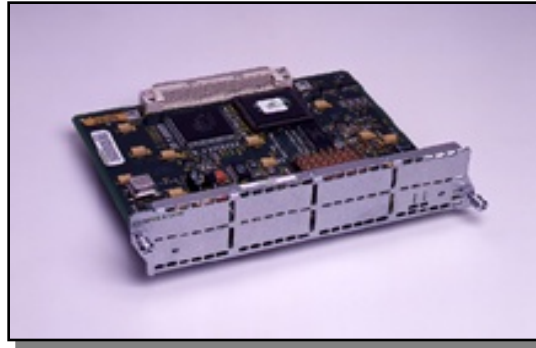
Hardware Encryption:

Tarjetas Advanced Integration Module (AIM) para diferente gama de routers Cisco.

3620/40

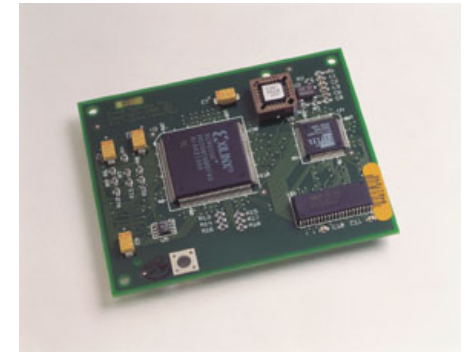
NM 4 Mbps

Network Module



3660

**AIM 8 Mbps,
1900**



IPSec and 3DES support

Interoperable with Cisco IOS
encryption s/w platforms

Optional layer 3 compression

Performance enhancements
through planned Cisco IOS updates



Localización de los dispositivos de cifrado (1/2)

2 alternativas para la ubicación del cifrado:

- **Cifrado de enlace a enlace**, cada nodo intermedio (router) debe descifrar los paquetes. **Cifrado en túnel**. Los datos (paquetes IP) van cifrados entre routers extremos, pero no en las LAN. Utilizado en VPN
- **Cifrado extremo a extremo**. Sólo los extremos pueden descifrar la información, pero las cabeceras de los paquetes han de viajar descifradas para que los routers puedan encaminar los paquetes, también es conocido como modo transporte

Una variante es cifrado mixto enlace-enlace, extremo-extremo, donde las cabeceras van cifradas enlace a enlace y los datos extremo a extremo.

Localización de los dispositivos de cifrado (2/2)

Pero con esto, a un intruso se le oculta las direcciones y los contenidos, pero no el **volumen de información** intercambiado. Para ocultar dicha información, se integra **tráfico de relleno**, para ocultar el volumen de información real.

Comandos gpg

- `gpg -k` - **lista las claves**
- `gpg --gen-key` - **crea clave pub priv**
- `gpg --armor --output myname_public_key.asc --export 'Name Surname'` - **exporta claves publica**
- `gpg --import johndoe.asc` - **importa**
- `gpg --encrypt --recipient 'Name Surname' file.txt` - **encripta**
- `gpg --output file.txt --decrypt file.txt.gpg` - **desencripta**